

Matriz de Evaluación PRAGMATIC Completa

Calificación de las 50 Métricas GQM-COSO bajo los 9 Criterios PRAGMATIC

Kit GQM-PRAGMATIC v2025.1 • España / UE • Abril 2026

"PRAGMATIC es el espejo incómodo que las organizaciones necesitan. Muestra no solo qué se mide, sino por qué debería medirse —o por qué debería dejarse de medir de una vez."

Instrucciones de Lectura de la Matriz

Escala de calificación por criterio: 1 (muy bajo) — 2 (bajo) — 3 (aceptable) — 4 (alto) — 5 (muy alto)

Criterio	Código	Descripción del criterio aplicado
Predictivo	P	¿La métrica anticipa problemas antes de que ocurran?
Relevante	R	¿Está directamente relacionada con objetivos del negocio y el Consejo?
Accionable	A	¿Un cambio en el valor genera una decisión o acción concreta?
Genuino	G	¿Mide lo que afirma medir, sin artefactos ni sesgo de medición?
Significativo	M	¿Tiene contexto suficiente para ser interpretado correctamente?
Preciso	Ac	¿Los datos son exactos con margen de error conocido y controlado?
Oportuno	T	¿Está disponible cuando se necesita para tomar la decisión?
Independiente	I	¿Su generación está libre de conflicto de interés?
Rentable	C	¿El coste de medición es proporcional al valor informativo?

Puntuación total máxima: 45 puntos | **Umbral de implementación recomendada:** ≥ 27

Clasificación: ■ Premium (36–45) | ● Aceptable (27–35) | ● Condicional (18–26) | ● Rediseñar (<18)

Componente I — Gobernanza (M-GOB)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-GOB-01	Frecuencia a revisión ciberriesgo en el Consejo	3	5	4	4	5	4	4	5	5	39	 Premium
M-GOB-02	% consensos con competencia ciberacreditada	2	5	3	3	4	3	3	5	4	32	 Aceptable
M-GOB-03	Nivel de actividad del Comité Ciber del Consejo	3	4	4	3	4	3	4	4	4	33	 Aceptable
M-GOB-04	Independencia del reporte del CISO al Consejo	4	5	5	3	4	3	4	5	5	38	 Premium

M- GOB- 05	Apeti to de ciber riesg o cuan tifica do en euros	4	5	5	4	5	4	4	4	4	39	 Prem ium
---------------------------	---	---	---	---	---	---	---	---	---	---	----	--

Componente II — Estrategia y Apetito de Riesgo (M-EST)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-EST-01	Nivel de integración ciber en el plan estratégico	3	5	4	3	4	3	4	4	4	34	 Aceptable
M-EST-02	Metodología de cuantificación de riesgo o utilizada	3	4	3	4	4	4	3	4	5	34	 Aceptable
M-EST-03	ALE total del portafolio de ciber riesgos (€/año)	4	5	5	3	5	3	4	4	3	36	 Premium

M-EST-04	Frecuencia de actualización de la cuantificación del riesgo	4	4	3	4	4	4	4	4	4	35	 Aceptable
M-EST-05	Ratio cobertura de seguro / ALE estimado	4	5	5	3	5	3	4	4	4	37	 Premium

Componente III-A — Detección y Respuesta (M-DET)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-DET-01	MTTD — Mean Time to Detect (horas)	4	5	5	5	5	4	5	3	3	39	 Premium
M-DET-02	MTTR — Mean Time to Respond (horas)	4	5	5	5	5	4	5	3	3	39	 Premium
M-DET-03	Tendencia trimestral del MTTD (delta %)	5	5	5	4	5	4	5	3	4	40	 Premium
M-DET-04	% incidentes detectados por controles propios	3	4	4	4	4	4	4	3	4	34	 Aceptable

M- DET- 05	Dwell Time medio del adversario (días)	5	5	5	4	5	3	4	3	3	37	 Premium
---------------------------	--	---	---	---	---	---	---	---	---	---	----	---

Componente III-B — Gestión de Vulnerabilidades (M-VUL)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-VUL-01	Time-to-Patch crítico: mediana días CVSS ≥ 9.0	5	5	5	5	5	4	4	3	4	40	 Premium
M-VUL-02	% CVE críticos sin parchear en >30 días	4	5	5	5	5	4	4	3	4	39	 Premium
M-VUL-03	% vulnerabilidades prioritizadas con EPSS	4	4	4	4	4	4	4	3	4	35	 Aceptable
M-VUL-04	Cobertura VM en activos OT/IoT (%)	4	5	5	4	5	3	4	3	4	37	 Premium

M- VUL- 05	% aplic acion es crític as con SBO M <90 días	4	4	4	4	4	4	4	3	4	35	 Acep table
---------------------------	---	---	---	---	---	---	---	---	---	---	----	--

Componente III-C — Gestión de Identidad y Acceso (M-IAM)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-IAM-01	% cuentas privilegiadas con MFA activo	5	5	5	5	5	5	4	3	4	41	 Premium
M-IAM-02	% accesos remotos y cloud con MFA	5	5	5	5	5	5	4	3	4	41	 Premium
M-IAM-03	Días desde última revisión de cuentas privilegiadas	4	5	4	4	5	4	4	3	4	37	 Premium
M-IAM-04	Tiempo medio de desprovisión en bajas (horas)	4	5	5	5	5	5	4	3	4	40	 Premium

M-IAM-05	% ident idade s no hum anas inve ntari adas y gobe rnad as	4	5	5	3	4	3	4	3	3	34	 Acep table
----------	--	---	---	---	---	---	---	---	---	---	----	--

Componente III-D — Riesgo de Terceros y SCM (M-SCM)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-SCM-01	% proveedores Tier-1 con evaluación <12 meses	4	5	5	4	5	4	3	4	3	37	 Premium
M-SCM-02	% proveedores Tier-1 con monitorización continua	5	5	5	4	5	4	4	4	3	39	 Premium
M-SCM-03	% contratos críticos con cláusulas de seguridad	3	5	4	4	4	4	3	4	4	35	 Aceptable

M-SCM-04	% servicios críticos con BC ante fallo de proveedor	4	5	5	4	5	4	3	4	3	37	 Premium
M-SCM-05	% apps críticas de terceros con SBO M monitorizado	4	4	4	3	4	3	3	3	3	31	 Aceptable

Componente III-E — Resiliencia y Continuidad (M-RES)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-RES-01	Ratio RTO real / RTO objetivo (%)	4	5	5	5	5	5	4	4	4	41	 Premium
M-RES-02	Ratio RPO real / RPO objetivo (%)	4	5	5	5	5	5	4	4	4	41	 Premium
M-RES-03	Número de pruebas DRP reales en 12 meses	3	4	4	5	4	5	4	4	4	37	 Premium
M-RES-04	% ejercicios table top con participación C-level	3	5	4	4	4	4	4	4	4	36	 Premium

M- RES- 05	% back ups críticos offline/in mutables verificados	4	5	5	5	5	5	4	3	4	40	 Premium
---------------------------	---	---	---	---	---	---	---	---	---	---	----	--

Componente III-F — Riesgos Emergentes: IA y PQC (M-EMG)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-EMG-01	% sistemas con inventario criptográfico completo	5	5	5	4	5	4	4	3	3	38	 Premium
M-EMG-02	Estado de la hoja de ruta PQC (0-3)	5	5	4	4	5	4	4	4	4	39	 Premium
M-EMG-03	% reglas SOC para patrones de ataque automatizado por IA	4	5	5	4	4	3	4	3	3	35	 Aceptable

M-EMG-04	% sistemas IA con evaluación de riesgo o pre-despliegue	4	5	5	4	5	4	4	4	3	38	 Premium
M-EMG-05	% datos vida útil >10 años evaluados para SNDL	5	5	4	4	5	3	3	3	3	35	 Aceptable

Componente V — Información y Reporte al Consejo (M-RPT)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-RPT-01	Frecuencia de reporte ciber al Consejo (veces/año)	3	5	4	4	5	4	4	5	5	39	 Premium
M-RPT-02	% indicadores del reporte en términos financieros	4	5	5	4	5	4	4	4	4	39	 Premium
M-RPT-03	Calidad comparativa estado/apetito en el reporte (0-3)	4	5	5	3	5	3	4	4	4	37	 Premium

M-RPT-04	Estado del protocolo de escalado ante incidentes (0-3)	4	5	5	4	5	4	5	4	4	40	 Premium
M-RPT-05	Tiempo evento o conocimiento del Consejo (horas)	4	5	5	5	5	5	5	3	4	41	 Premium

Métricas Financieras ROSI/ROI (M-ROI)

Cód.	Métrica	P	R	A	G	M	Ac	T	I	C	Total	Clase
M-ROI-01	ROSI del programa de ciberseguridad (%)	4	5	5	4	5	3	4	4	3	37	 Premium
M-ROI-02	Gasto ciber / ingresos totales (%)	3	5	4	5	4	5	4	5	5	40	 Premium
M-ROI-03	Delta ALE: reducción de riesgo por programa (€/año)	4	5	5	3	5	3	4	4	4	37	 Premium
M-ROI-04	Payback periodo de controles principales (meses)	4	5	5	4	5	4	4	4	4	39	 Premium

M-ROI-05	Ratio inversión ciber / ALE total (%)	4	5	5	4	5	4	4	4	4	39	Premium
----------	---------------------------------------	---	---	---	---	---	---	---	---	---	----	---------

Resumen Estadístico de la Matriz PRAGMATIC

Indicador	Valor
Total de métricas evaluadas	50
Métricas Premium (36-45) 	37 (74%)
Métricas Aceptables (27-35) 	13 (26%)
Métricas Condicionales (<27) 	0 (0%)
Puntuación media PRAGMATIC	37.4 / 45
Puntuación mínima	31
Puntuación máxima	41
Criterio más fuerte (promedio)	Relevante (R): 4.9/5
Criterio más débil (promedio)	Independiente (I): 3.5/5

Análisis por Criterio PRAGMATIC (promedio de las 50 métricas)

Criterio	Promedio	Interpretación
Predictivo (P)	3.9 / 5.0	Nivel aceptable — oportunidades de mejora
Relevante (R)	4.8 / 5.0	Fortaleza sistémica del conjunto de métricas
Accionable (A)	4.6 / 5.0	Fortaleza sistémica del conjunto de métricas
Genuino (G)	4.1 / 5.0	Alta calidad — seguir fortaleciendo
Significativo (M)	4.7 / 5.0	Fortaleza sistémica del conjunto de métricas
Preciso (Ac)	3.9 / 5.0	Nivel aceptable — oportunidades de mejora
Oportuno (T)	4.0 / 5.0	Nivel aceptable — oportunidades de mejora
Independiente (I)	3.7 / 5.0	Nivel aceptable — oportunidades de mejora
Rentable (C)	3.8 / 5.0	Nivel aceptable — oportunidades de mejora

Hallazgos Clave de la Evaluación PRAGMATIC

Fortalezas del conjunto de métricas:

1. **Alta Relevancia ($R \approx 4.9/5$):** La totalidad de las métricas responde directamente a objetivos de negocio o regulatorios con impacto tangible. No hay métricas puramente técnicas desconectadas del lenguaje del Consejo.
2. **Alta Accionabilidad ($A \approx 4.4/5$):** La mayoría de las métricas permiten generar una acción o decisión concreta ante una variación de su valor. Especialmente destacables las métricas de la familia M-DET, M-IAM y M-RES.
3. **Alta Significatividad ($M \approx 4.6/5$):** La contextualización de cada métrica con benchmarks sectoriales (IBM, ENISA, CIS Controls) garantiza que el Consejo pueda interpretar el dato sin necesitar traducción técnica.

Alta Relevancia ($R \approx 4.9/5$): La totalidad de las métricas responde directamente a objetivos de negocio o regulatorios con impacto tangible. No hay métricas puramente técnicas desconectadas del lenguaje del Consejo.

Alta Accionabilidad ($A \approx 4.4/5$): La mayoría de las métricas permiten generar una acción o decisión concreta ante una variación de su valor. Especialmente destacables las métricas de la familia M-DET, M-IAM y M-RES.

Alta Significatividad ($M \approx 4.6/5$): La contextualización de cada métrica con benchmarks sectoriales (IBM, ENISA, CIS Controls) garantiza que el Consejo pueda interpretar el dato sin necesitar traducción técnica.

Áreas de mejora identificadas:

4.

Independencia ($I \approx 3.5/5$): El criterio más débil del sistema. Las métricas cuyo dato es generado por el mismo equipo que diseña los controles presentan riesgo de sesgo. **Recomendación:** Establecer auditoría independiente o validación cruzada para las métricas de las familias M-GOB, M-RPT y M-IAM al menos anualmente.

5.

Precisión ($Ac \approx 3.8/5$): Las métricas basadas en modelos de cuantificación financiera (M-EST-03, M-ROI-01, M-ROI-03) tienen precisión inherentemente limitada por la calidad de los datos de entrada al modelo FAIR/ALE. **Recomendación:** Documentar los rangos de incertidumbre (intervalos de confianza) junto al valor puntual.

6.

Oportunidad en riesgos emergentes ($T \approx 3.6/5$ para M-EMG): Las métricas de la familia de riesgos emergentes (especialmente M-EMG-05 sobre datos SNDL) presentan menor oportunidad porque los datos requieren procesos de auditoría periódicos. **Recomendación:** Automatizar parcialmente el inventario criptográfico con herramientas de crypto-agility scanning.

Independencia ($I \approx 3.5/5$): El criterio más débil del sistema. Las métricas cuyo dato es generado por el mismo equipo que diseña los controles presentan riesgo de sesgo. **Recomendación:** Establecer auditoría independiente o validación cruzada para las métricas de las familias M-GOB, M-RPT y M-IAM al menos anualmente.

Precisión ($Ac \approx 3.8/5$): Las métricas basadas en modelos de cuantificación financiera (M-EST-03, M-ROI-01, M-ROI-03) tienen precisión inherentemente limitada por la calidad de los datos de entrada al modelo FAIR/ALE. **Recomendación:** Documentar los rangos de incertidumbre (intervalos de confianza) junto al valor puntual.

Oportunidad en riesgos emergentes ($T \approx 3.6/5$ para M-EMG): Las métricas de la familia de riesgos emergentes (especialmente M-EMG-05 sobre datos SNDL) presentan menor oportunidad porque los datos requieren procesos de auditoría periódicos. **Recomendación:** Automatizar parcialmente el inventario criptográfico con herramientas de crypto-agility scanning.

Ficha PRAGMATIC Detallada — Métricas de Máxima Prioridad

Las siguientes fichas detallan el razonamiento criterio a criterio para las métricas con mayor impacto estratégico (puntuación ≥ 40):

Ficha PRAGMATIC: M-IAM-01 — % Cuentas Privilegiadas con MFA Activo

Criterio	Puntuación	Razonamiento
P Predictivo	5/5	Si la cobertura de MFA cae por debajo del 100%, predice exposición al vector de ataque de credenciales comprometidas, responsable del 74% de las brechas (Verizon DBIR 2025).
R Relevante	5/5	CIS Controls v8 (Control 6.3) la considera obligatoria. NIS2 Art. 21(2j) la exige. El Consejo comprende intuitivamente el riesgo de cuentas sin segundo factor.
A Accionable	5/5	Si la puntuación < 100%, la acción es directa: identificar y habilitar MFA en las cuentas descubiertas. Sin ambigüedad de interpretación.
G Genuino	5/5	El dato proviene de la plataforma IAM/PAM con informes automatizados. Difícil de manipular sin dejar rastro en los logs de auditoría.
M Significativo	5/5	El benchmark es inequívoco: 100% es el objetivo. Cualquier valor inferior está justificado sólo si existe compensación documental.
Ac Preciso	5/5	El dato es binario por cuenta (tiene MFA / no tiene MFA), por lo que la precisión es muy alta si el inventario de cuentas privilegiadas es completo.
T Oportuno	4/5	La plataforma PAM puede reportar en tiempo real. El 4 refleja que en organizaciones sin PAM la recolección puede requerir procesos manuales trimestrales.
I Independiente	3/5	El equipo IAM genera el dato y podría excluir cuentas 'de servicio' de la contabilización. Requiere auditoría independiente de la completitud del inventario.

C Rentable	4/5	La extracción del dato desde una plataforma PAM es automática y tiene coste marginal mínimo. Sin PAM, el coste de inventariado manual es relevante.
TOTAL	41/45  Premium	Métrica de implementación obligatoria. Control compensatorio: auditoría semestral independiente del inventario de cuentas privilegiadas.

Ficha PRAGMATIC: M-DET-03 — Tendencia Trimestral del MTTD (delta %)

Criterio	Puntuación	Razonamiento
P Predictivo	5/5	Una tendencia al alza del MTTD predice deterioro de la postura de detección antes de que se materialice un incidente mayor. Es una métrica adelantada (leading indicator).
R Relevante	5/5	El MTTD es el KPI más citado por el Consejo y el regulador como indicador de la salud del SOC. IBM Cost of Data Breach 2025 confirma: cada hora adicional de MTTD aumenta el coste de la brecha.
A Accionable	5/5	Una tendencia positiva (MTTD en aumento) activa la revisión de reglas de detección SIEM, inversión en threat intelligence y revisión de la cobertura de sensores.
G Genuino	4/5	Requiere que los incidentes previos al ticket formal estén correctamente timestamped. Riesgo: subregistro de la hora de compromiso real en incidentes sin forense completo.
M Significativo	5/5	El delta porcentual trimestral es más interpretable que el valor absoluto: un MTTD de 72 horas puede ser excelente en algunos sectores y catastrófico en otros. La tendencia es universal.
Ac Preciso	4/5	Precisión alta si el SIEM está bien calibrado y los tiempos de compromiso son verificables. Incertidumbre inherente en incidentes sin evidencia de timestamp de compromiso inicial.
T Oportuno	5/5	El cálculo trimestral es compatible con el ciclo de reporte al Consejo. Puede calcularse en tiempo real sobre el SIEM si existe.

I Independiente	3/5	El SOC que genera el dato podría tener incentivo perverso para clasificar tardíamente los incidentes. Requiere auditoría independiente de los registros de tiempos de detección.
C Rentable	4/5	Si existe SIEM, el cálculo es automático y de coste marginal nulo. Sin SIEM, el coste de reconstrucción manual de la línea temporal de incidentes es elevado.
TOTAL	40/45  Premium	Implementar como KRI (Key Risk Indicator) formal en el dashboard del CISO y en el reporte trimestral al Consejo.

Ficha PRAGMATIC: M-VUL-01 — Time-to-Patch Crítico (CVSS ≥ 9.0)

Criterio	Puntuación	Razonamiento
P Predictivo	5/5	El TTP de vulnerabilidades críticas predice directamente la probabilidad de explotación: con TtE <6 horas (CISA KEV 2025), parchear tardíamente es estadísticamente equivalente a no parchear.
R Relevante	5/5	Citada explícitamente en la Directiva NIS2 (Art. 21.2e) y el ENS (Medida op.exp.4). Referenciada por ENISA como uno de los tres indicadores de madurez más críticos en el sector.
A Accionable	5/5	El tiempo en días es directamente accionable: activa la revisión del proceso de patch management, la comunicación con el área IT y la gestión de excepciones temporales con compensatorios.
G Genuino	5/5	El dato proviene del escáner de vulnerabilidades (Qualys, Tenable, Rapid7), que timestampa automáticamente detección y remediación. Difícil de manipular si el escáner es externo.
M Significativo	5/5	Benchmarks ampliamente disponibles: CISA recomienda <48h para KEV; CIS Controls v8 <7 días para críticas; ENISA indica mediana sectorial de 30+ días. El contexto es inequívoco.
Ac Preciso	4/5	Precisión alta en entornos con escaneo continuo. Menor en entornos con cobertura parcial de activos (OT, shadow IT, cloud no registrado en CMDB).
T Oportuno	4/5	Si el escáner genera alertas automáticas, el dato es casi en tiempo real. La mediana puede calcularse mensualmente para el reporte.

I Independiente	3/5	El equipo de operaciones IT que debe parchear también suele tener acceso al escáner. Recomendable: escáner externo o validación independiente de cierre de vulnerabilidades.
C Rentable	4/5	Altamente rentable: los escáneres de vulnerabilidades son herramientas de coste conocido con ROI amplísimo dado el impacto de las brechas por vulnerabilidades no parcheadas.
TOTAL	40/45  Premium	KRI crítico (IAT). Debe aparecer en el dashboard mensual del CISO y en el reporte trimestral al Consejo.

Matriz PRAGMATIC Completa — Kit GQM-PRAGMATIC v2025.1 | Abril 2026

Metodología: Brotby & Hinson (2013) PRAGMATIC · NIST SP 800-55 Rev. 2 (2022) · ISACA CISM · ISO/IEC 27004:2016